Captured: compliance audit

EU AI Act and GDPR, first pass. 13 October 2026. Branch `ai-act-transparency` (PR #67).

> **Summary.** Under the EU AI Act the app is **limited risk**. Its one critical gap, telling users plainly that an AI answers, is fixed in PR #67, along with labelling the tutor's answers; the label on saved rules is partly done. Under GDPR there are **two critical gaps**, neither fixed: there is no privacy policy, and users cannot delete their own account. Both were already listed in `HANDOFF.md` under "When more people use the app".

1. EU AI Act

Classification: limited risk (Article 50 transparency only). Nothing is prohibited or high-risk: the tutor explains grammar and does not grade learners, place them at a level, decide admission or watch tests (Annex III, point 3). The learner's level is chosen in Settings, and flashcard scheduling is ordinary code. Captured offers its own AI system under its own name on top of a general-purpose model, so it is the **provider** for Article 50(1) and 50(2).

Article 50 criterion	Result at audit	Now
Chatbot discloses AI at or before first interaction	Fail (borderline)	Fixed in PR #67
AI-generated content labelled, visibly and machine-readably	Fail	Fixed for answers; partly for saved rules
Deepfakes flagged	Pass / not applicable	No change needed

Critical

1. **The Tutor page did not plainly say an AI answers** (Article 50(1), in force). The heading read "Tutor" and the only signal was a small grey "Model: Claude Sonnet 5.5 by Anthropic" line, never using the word AI (`src/components/tutor/TutorChat.tsx`).
   Fixed (PR #67): the line now reads "Answers are written by an AI model, Claude Sonnet 5.5 by Anthropic."

Warning

2. **Tutor answers were not labelled as AI-generated** (Article 50(2), applies from 2 December 2026). Answer cards and merged drafts had no label and no machine-readable mark (`src/components/tutor/AnswerCard.tsx`).
   Fixed (PR #67): "AI-generated" under every answer's title, and `data-ai-generated="true"` on the card.
3. **Rules saved from the tutor lost their origin.** On the rule page and in the backup file they looked like the learner's own writing (`SaveAsRuleDialog.tsx`, `src/lib/rules.ts`, `src/lib/backup.ts`).
   Partly fixed (PR #67): the rule page shows "Written by: AI, saved from the tutor", read from the existing conversation link. The label goes if that conversation is deleted, and backups do not carry it; a column on `items` would make it permanent.

Suggestions

4. Say on the landing page and at sign-up that the app includes an AI tutor, so disclosure comes before the first interaction. **Open** (overlaps the SEO list in `HANDOFF.md`).
5. A short "AI can make mistakes; check important points" note. **Declined by the owner** (", and can be wrong" was taken off the Tutor line).
6. Tell the tutor in its system prompt to confirm it is an AI if asked (`src/lib/tutor.ts:206`). **Open**
7. Label the demo video's narration as an AI voice. Not legally required (a stock HeyGen voice, no real person imitated). **Open**
8. AI literacy (Article 4, in force since 2 February 2025) covers the people who build and run the system, not users. For a solo developer, a brief written note of the tutor's limits is enough. **Open**
9. **Watch item:** if the tutor ever grades or places learners, or is sold to schools to assess students, the classification must be redone.

2. GDPR

Criterion	Result
A privacy policy exists and lists every category of data	Fail: there is no policy
A lawful basis is stated for each purpose	Fail
Every outside service receiving personal data is named	Fail
Retention periods and user rights are stated	Fail
Users can export their own data	Fail (partial)
Users can delete their account and all its data	Fail
Consent obtained where consent is the basis	Pass (not applicable: no analytics, marketing or tracking; only the strictly necessary session cookies)
No personal data written to logs	Pass: every `console.error` logs fixed text or status codes only
Breach readiness	Fail

What the app holds: account email, password hash (kept by Supabase), sign-in tokens and session cookies; words, phrases, verb tables, grammar rules, settings, collections and sources; review history and schedules; tutor questions, answers and their embeddings, usage, searches and plan; feedback name, email, text and the account's email and user id; and the browser signals Cloudflare Turnstile reads.

Critical

1. **No privacy policy.** There is no privacy page and nothing in the README. Users are not told that tutor questions go to OpenRouter and on to Anthropic, that their embeddings are made by a third-party model (Qwen through OpenRouter), or that feedback passes through Resend (Articles 13 and 14). **Open**
2. **No way for users to delete their account.** There is no route and nothing in Settings; today the owner would delete the user by hand in the Supabase dashboard (Article 17). The data already cascades from `auth.users`, so a server-side route using the admin API is all that is missing. **Open**

Warning

3. **No processor list or transfer basis.** Supabase, Vercel, OpenRouter, Anthropic, Resend and Cloudflare all receive personal data, mostly in the US. Their data processing agreements, the transfer safeguards (SCCs or the Data Privacy Framework), and OpenRouter's retention and training settings need confirming and writing down; the tutor's request sets no data-collection or zero-retention preference (`src/lib/tutorServer.ts:155-177`). **Open**
4. **Export is incomplete.** The backup covers words, phrases, verb tables, rules and settings only (`src/lib/backup.ts:132`). Tutor conversations and answers, review and progress history, usage and plan are left out, so access and portability (Articles 15 and 20) are only partly met. **Open**
5. **No retention periods.** Tutor answers, embeddings and review history are kept until the user deletes them; feedback emails holding the account email and user id stay in the owner's mailbox (`src/app/api/feedback/route.ts:70`). Only the nightly `tutor_searches` cleanup limits anything. **Open**
6. **No breach process.** No security contact, no alerting, and no procedure for the 72-hour notice to the regulator; errors reach Vercel's logs and nothing else. **Open**

Suggestions

7. Add a contact point (a privacy or security email, or `/.well-known/security.txt`) and a short incident runbook in `Docs/`.
8. Drop the user id from feedback emails, or name it in the policy; the account email alone may be enough.
9. Advise users, in the policy or by the tutor's question box, not to put personal data in tutor questions, since the text goes to third-party models.
10. When account deletion is built, tell the user that copies already sent to OpenRouter, Anthropic and Resend follow those services' own retention.

3. Suggested order

1. Merge PR #67 (AI disclosure and labels).
2. Write a privacy page: what is held, why, which services receive it, how long it is kept, the user's rights and a contact. Public, outside `(workspace)`, added to the proxy's public paths and the sitemap.
3. Build account deletion: a server-only route with the admin API, behind a confirmation in Settings. It is the first thing that needs a service-role key, so the rule in `CLAUDE.md` changes with it.
4. Widen the export to tutor conversations and review history.
5. Confirm the processors' terms and OpenRouter's retention settings, and write the breach runbook.

Produced by the `eu-ai-act-compliance` and `gdpr-compliance` agents in Claude Code, with the main findings checked against the code. This is an automated first-pass signal, not a legal ruling, and not a substitute for review by a qualified lawyer or data protection officer. Confirm classifications and dates against the current text of Regulation (EU) 2024/1689 and Regulation (EU) 2016/679.